Class 5 | NotesApp Security Audit

Full name: 陈子明 Chen Ziming | **CHU ID:** 2023905333
Lab partner: 吴彦澜 Wu Yanlan | **CHU ID:** 2023905420
Date: 22 October 2026

Scope: Login traffic and password storage in our own local NotesApp, using loopback captures and six simulated course accounts. No third-party systems were tested.

Lab 1 - Traffic in transit

Finding 1 | Login over plain HTTP

Exposed: The login username and password were readable in POST /login on port 8080. The exact body was **username=alice&password=alicepw**.

Who could read it: An observer able to intercept the unencrypted browser-to-server connection. **Severity: High**, because stolen credentials could allow account access.

Fix: Put an nginx HTTPS reverse proxy in front of Flask, remove the published Flask port 8080, and redirect port 80 to HTTPS.

```
POST /login HTTP/1.1
Host: 127.0.0.1:8080
Connection: keep-alive
Content-Length: 31
```

```
username=alice&password=alicepw
HTTP/1.1 302 FOUND
```

Figure 1. Two excerpts from the same original stream: request headers and submitted credentials. Capture: login-http.pcapng, packet 348, TCP stream 9. Packet 350 returned HTTP 302.

Fix verified | HTTPS re-capture

The HTTPS capture contains 75 packets and negotiated TLS 1.3. TCP stream 6 carries encrypted data. Searches across all reassembled TCP streams found no plaintext login credentials; no TLS session keys were supplied. The dashboard and access records confirm successful HTTPS login.

Additional checks: HTTP / and /login returned 301 redirects to HTTPS; direct port 8080 was closed. Lab 1 did not change the database contents.

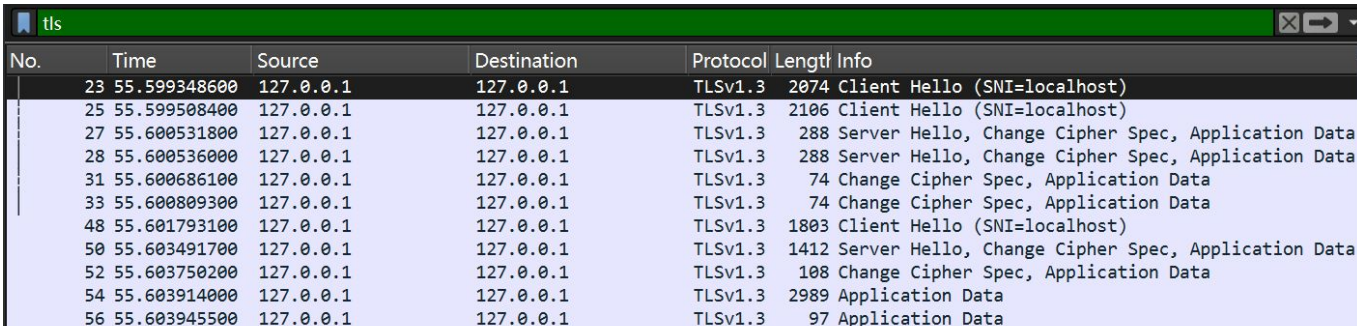
Finding 2 | Certificate trust

GitHub issuer: Sectigo Public Server Authentication CA DV E36; the displayed chain leads to Sectigo Public Server Authentication Root E46. **Local issuer:** localhost, matching the subject; the local chain contains only localhost.

Trust missing: A chain to a root CA trusted by the browser. Edge showed **NET::ERR_CERT_AUTHORITY_INVALID**.

Verdict: Encryption protects transmitted content, but it does not by itself establish server identity. The lab's self-signed server is not automatically trusted by the browser.

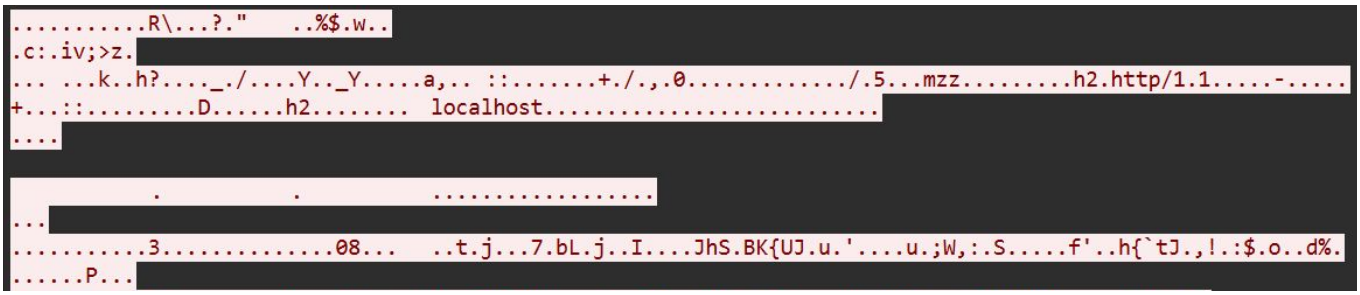
Lab 1 | HTTPS and certificate evidence



tls

No.	Time	Source	Destination	Protocol	Length	Info
23	55.599348600	127.0.0.1	127.0.0.1	TLSv1.3	2074	Client Hello (SNI=localhost)
25	55.599508400	127.0.0.1	127.0.0.1	TLSv1.3	2106	Client Hello (SNI=localhost)
27	55.600531800	127.0.0.1	127.0.0.1	TLSv1.3	288	Server Hello, Change Cipher Spec, Application Data
28	55.600536000	127.0.0.1	127.0.0.1	TLSv1.3	288	Server Hello, Change Cipher Spec, Application Data
31	55.600686100	127.0.0.1	127.0.0.1	TLSv1.3	74	Change Cipher Spec, Application Data
33	55.600809300	127.0.0.1	127.0.0.1	TLSv1.3	74	Change Cipher Spec, Application Data
48	55.601793100	127.0.0.1	127.0.0.1	TLSv1.3	1803	Client Hello (SNI=localhost)
50	55.603491700	127.0.0.1	127.0.0.1	TLSv1.3	1412	Server Hello, Change Cipher Spec, Application Data
52	55.603750200	127.0.0.1	127.0.0.1	TLSv1.3	108	Change Cipher Spec, Application Data
54	55.603914000	127.0.0.1	127.0.0.1	TLSv1.3	2989	Application Data
56	55.603945500	127.0.0.1	127.0.0.1	TLSv1.3	97	Application Data

Figure 2. Original loopback packet list: TLS 1.3 handshakes and encrypted records to localhost. In the saved capture, packet 50 is the Server Hello for TCP stream 6; packet 54 carries Application Data.



```
..........R\...?."    ..%$.w..
.c:.iv;>z.
... ...k..h?...._./....Y.._Y.....a,.. ::.......+./.,.0.............../.5...mzz.........h2.http/1.1.....-.....
+...::.........D......h2........ localhost.............................
....

          .          .          ..................
...
..........3..............08...   ..t.j...7.bL.j..I....JhS.BK{UJ.u.'....u.;W,:.S.....f'..h{`tJ.,!.:$.o..d%.
......P...
```

Figure 3. Excerpt from Follow TCP Stream 6. Readable localhost and protocol names are handshake metadata. Application Data can also carry encrypted TLS 1.3 handshake messages; it is not a count of HTTP requests.

Certificate comparison

GitHub - issuer field



颁发者

公用名(CN)	Sectigo Public Server Authentication CA DV E36
组织(O)	Sectigo Limited
组织单位(OU)	<不是证书的一部分>

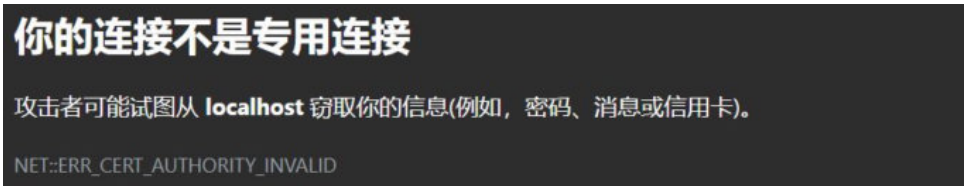
Localhost - issuer field



颁发者

公用名(CN)	localhost
组织(O)	<不是证书的一部分>
组织单位(OU)	<不是证书的一部分>

Figure 4. Original issuer fields. GitHub: Sectigo DV E36; localhost: localhost. Full subject fields and the displayed chains are preserved in the original screenshots.



你的连接不是专用连接

攻击者可能试图从 **localhost** 窃取你的信息(例如，密码、消息或信用卡)。

NET::ERR_CERT_AUTHORITY_INVALID

Figure 5. Edge's untrusted-certificate warning. The observed authority error is distinct from a hostname mismatch.

Lab 1 state: HTTPS enabled with a self-signed lab certificate. Optional redirect check passed; the optional wrong-domain test and cleanup back to HTTP were not performed.

Lab 2 | Password storage audit

The application originally stored legacy plaintext. The MD5 exercise used a separate generated six-account dump; it was not an MD5 export of the live database.

Finding 1 | Unsalted MD5

Pre-test prediction: 6/6 accounts in 10 ms. **Measured:** 4/6 in **0.1607 ms**, using the public wordlist's 170 nonblank candidates.

Why these fell: liwei / 123456, aisha / password1, tomk / qwerty123 and sofia / iloveyou were in the list. The script hashes guesses and compares digests; it does not reverse MD5.

Held out: marie / mariepw and raj / Gv7#pLm2!xQ were absent from these candidates. Surviving one wordlist does not establish safety against other guesses.

Severity: High. A stolen table permits offline guesses without online login controls. **Fix:** unique salted Argon2id hashes and upgrade on successful legacy login.

```
Public wordlist: 170 candidates
cracked 4 / 6 in 0.161 ms
  liwei : 123456
  aisha : password1
  tomk : qwerty123
  sofia : iloveyou
Held out: marie, raj
```

Figure 6. Original interactive terminal output. The saved matching-loop timer is 160,700 ns (0.1607 ms); the console rounds to 0.161 ms. File reading and printing are excluded.

Finding 2 | Cost of a guess, measured

Pre-test prediction: Argon2 would be about 10 times slower than MD5.

Hash	Estimated guesses / second	Estimated guesses / day
MD5	3,336,597	288,282,016,688
Argon2id	27.105	2,341,905

One Argon2 hash took **36.893 ms**; the measured per-operation slowdown was about **123,097 times**.

Method: 100,000 MD5 hexdigest operations followed by one fresh Argon2 hash, timed with perf_counter_ns in the same Python 3.11.17 web container. Argon2id: 64 MiB memory, time cost 3, parallelism 4, 16-byte random salt, 32-byte output.

Verdict: MD5 makes bulk offline guessing cheap. Argon2id increases per-guess cost substantially, but common passwords can still be recovered; this test cannot establish that an attacker would give up.

Daily values are rates multiplied by 86,400. They are linear estimates, not observed 24-hour attacks or universal GPU rates. Fresh-hash timing is a guess-cost proxy, not an optimized cracking benchmark.

Lab 2 | Migration and final state

Prediction: Alice's stored password would become a hash. A correct legacy login checks the old value once and writes a new Argon2id hash. Later logins verify that stored hash.

Before: alicepw
After (prefix): $argon2id$v=19$m=65536,t=3,p=4$...
The actual PostgreSQL SELECT output and full encoded value are preserved in lab2/results/alice-storage.txt.

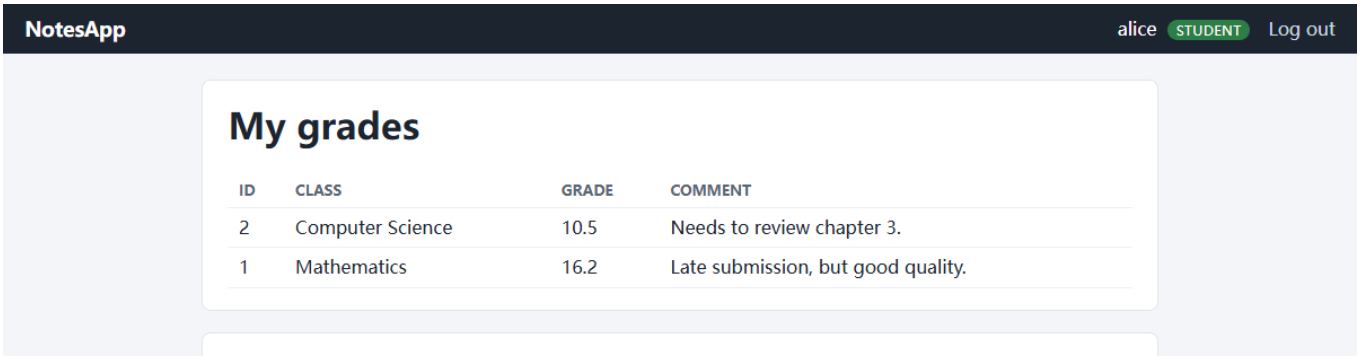


Figure 7. Real NotesApp dashboard after the first successful login, recorded by an automated Edge check. The separate database query confirms password migration.

Live check	Observed result
Incorrect legacy password	Rejected; no migration
Correct legacy login	Accepted; alice password upgraded
Incorrect password after migration	Rejected; stored hash unchanged
Logout and second correct login	Accepted; stored hash unchanged
Preservation	Other 34 users and all non-user table digests unchanged

Final state: Argon2id login is running (argon2-cffi 23.1.0). Alice is migrated; 34 of 35 accounts remain legacy until a successful login. HTTPS remains enabled. New-account creation and other teaching vulnerabilities are outside this change; the username SQL-concatenation flaw is retained for the later course session.

Additional checks: 15 password checks and 75 existing comment/HMAC checks passed. The password helper has 100% statement/branch coverage. Five subsequent Argon2 hashes had a median of 32.051 ms; five existing-hash verifications had a median of 31.058 ms. These are distinct workloads, not an Argon2 wordlist attack.

Optional rule test: Adding six <username>pw guesses to the 170 public entries recovered marie as well: 5/6 in 0.1728 ms. Raj remained unmatched in these 176 guesses. The original 4/6 result is unchanged.

Evidence provenance: Lab 1 captures and the initial MD5 run were interactive. Migration screenshots and the later performance/rule checks were automated locally. The automation accepted only this local lab's self-signed HTTPS certificate; it did not establish public CA trust.

Course sources: Lab 1 - Traffic-in-transit audit; Lab 2 - Password storage audit. Full original screenshots, captures, raw JSON and the implementation patch accompany this report.